Security, Privacy, Licensing & Compliance

The build contract for handling accounts, keys, user media, third-party assets and generated video. If a feature conflicts with this document, the feature does not ship until this document is amended.

Product: AI Video Studio - web, Windows + Mac

Stack: Next.js / FastAPI / Redis + Celery

Applies to: Spike, MVP, v1

Item	Detail
Pipeline in scope	Topic, research, script, voice (recorded or AI), voice cleanup, visual plan, generation into project, motion graphics, timeline edit, captions / sound, preview, render (1080p in MVP, 4K later), publish pack (Shorts / Reels, thumbnails, title / description).
Storage in scope	Project files, voice recordings, generated media and renders in R2 / S3-compatible object storage. Metadata, jobs and audit events in the application database.
Out of scope	Native desktop apps, offline editing, and any feature that downloads third-party video by default. YouTube sourcing is opt-in only - see Section 5.
Owners	One named owner each for: auth and keys, data retention, licensing, moderation. No shared admin accounts. Owner names are recorded in the internal runbook, not in client code.

1 Operating principles

- **Least privilege everywhere.** Users see only their own projects. Workers get short-lived, scoped access to the exact objects a job needs - never bucket-wide credentials.
- **No secrets in code, logs or renders.** API keys, tokens and signed URLs never appear in git, Celery payloads in plaintext logs, error messages shown to users, or exported files.
- **Provenance on every asset.** Every clip, image, track and voice in a project carries a source record. No record, no render.
- **Delete by default.** Temporary media expires automatically. Keeping data needs a reason stated in Section 4; everything else is deleted on schedule.
- **User content is not training data.** Voice recordings, scripts and uploads are never used to train models or shown to other users without separate, written opt-in consent.
- **Estimates stay labelled.** All third-party costs in this document are estimates or ranges and must be re-checked at procurement time.

Non-negotiable: No launch - public or paid beta - without the launch gate in Section 8 passing in full. A partial pass is a no-go.

2 Authentication and accounts

Decision	Specification
Sign-in methods (MVP)	Email + password and Google OAuth. Magic links, phone OTP and passkeys are not in MVP.
Passwords	Minimum 10 characters. Checked against a breached-password list at sign-up and reset. Stored only as a salted hash (Argon2id or the auth provider equivalent) - never in our own tables in plaintext or reversible form.
Sessions	httpOnly, Secure, SameSite=Lax cookies. No tokens in localStorage. Idle timeout 7 days, absolute timeout 30 days. Logout revokes the session server-side.
Email verification	Required before first render or any paid action. Unverified accounts can create one draft project only.
Password reset	Single-use link, expires in 60 minutes. Reset revokes all other sessions. Response is identical whether or not the email exists.
Rate limits	Login, sign-up, reset and verification endpoints are rate-limited per IP and per account, with exponential backoff. Repeated failures trigger a CAPTCHA challenge and an audit event.
Roles	**User** - own projects only. **Support** - metadata only, no media access without a logged, time-boxed grant. **Admin** - moderation and billing operations. **Worker** - service identity, no interactive login.
Admin protection	Multi-factor authentication is mandatory for Admin and Support. Admin actions require re-authentication for destructive operations (delete user, refund, purge project).
Account deletion	Self-serve in settings. Soft-delete for 14 days (recoverable by the user), then hard purge of projects, media and keys. Billing records are retained separately as required - see Section 4.

3 Secrets and BYOK (bring your own key)

Two classes of key exist, and they are handled differently. Mixing them is a defect.

Platform keys - ours

- LLM, TTS, stock and storage credentials live in a managed secret store / KMS, injected at runtime as environment variables.
- Never committed to git. Pre-commit and CI secret scanning block merges that contain key-like strings.
- Rotated at least every 90 days and immediately on staff exit or suspected leak.
- Separate keys per environment: development, staging, production. Development never uses production keys or real user media.

User BYOK - theirs

- Optional. A user may supply their own LLM / TTS / image provider key to use their own quota instead of platform credits.
- Encrypted at rest with envelope encryption (per-key data key, KMS-wrapped). Stored ciphertext only; the plaintext exists in memory only during a job.
- Shown masked in the UI (last 4 characters only). Never returned in full by any API after saving.
- Sent only to the provider the user selected, only for that user’s jobs. Never logged, never included in analytics, never shared across accounts.
- User can revoke instantly in settings; revocation deletes the ciphertext and fails queued jobs that depended on it, with a clear message.
- Validation on save: one low-cost test call. A failed key is not stored.

Logging rule: request logs, Celery task arguments and error traces are scrubbed for Authorization headers, cookies, signed URLs and any field named key, token, secret or password before they are written. A log line containing a raw key is treated as an incident - see Section 8.

4 Data, PII and media retention

What we collect - and what we do not

- **Account:** name, email, auth identifiers, plan and billing status.
- **Project:** topic, research notes, scripts, prompts, timeline data, asset provenance records.
- **Media:** user voice recordings and uploads, AI voice output, generated images / clips, captions, previews and final renders.
- **Operational:** job status, render duration, storage size, error codes, audit events.
- **We do not collect:** contacts, location beyond country for tax / billing, microphone access outside an explicit recording session, or files from the user's device beyond what they upload.

Voice is sensitive. A voice recording can identify a person. It is treated as sensitive personal data: encrypted in transit (TLS 1.2+) and at rest, access-logged, and never used for voice cloning of a different person. AI voice cloning of the user's own voice requires an in-product consent step recorded with timestamp; cloning any third party's voice is prohibited - see Section 7.

Retention schedule - enforced by automated jobs, not by hand

Data	Retention	Deletion method
Raw voice takes and rejected takes	30 days after project render, or on project delete	Object delete + database row purge; deletion written to audit log
Intermediate files (cleaned audio, scene renders, caption drafts)	7 days after final render	Lifecycle rule on the temp prefix; no manual step
Final renders and publish pack	While account is active; 90 days after account closure	Object delete on closure job
Project metadata and scripts	While account is active; purged 14 days after hard account deletion	Database purge job
BYOK ciphertext	Until user revokes or account is hard-deleted	Immediate delete on revoke
Audit log	12 months online, then archived 24 months	Append-only store; no user-level delete
Billing / invoice records	As required for tax and accounting in the selling jurisdiction	Retained separately from product data, access limited to Admin
Support / moderation records	12 months after case closure	Case purge job; legal holds override

User rights - built into the product, not handled by email

- **Export:** user can download their projects, scripts, media list with provenance, and account data from settings.
- **Delete:** single-project delete and full-account delete, both self-serve, both confirmed in-product and completed within the periods above.
- **Correct:** name and email editable in settings; email change requires re-verification.
- **Privacy notice:** plain-language notice at sign-up covering what is stored, the processors used (hosting, storage, LLM / TTS providers, stock providers, payment provider), retention periods above, and the deletion path. Any new processor is added to the notice before it receives data.

5 Copyright and platform terms of service

> **Default rule:** visuals come from licensed stock - Pexels and Pixabay in MVP - or from generation, or from the user's own uploads. That is the only path enabled by default. Everything else is an exception with a record attached.

Licensed stock - the default

- Use only the providers' official APIs. Store the asset ID, provider, licence type, source page URL and retrieval date for every asset at import time.
- Respect each provider's current terms: attribution where required, no resale of unaltered stock as a standalone product, no use in a trademark or logo, no implying endorsement by people pictured.
- If a provider changes its terms or an asset is withdrawn, affected projects are flagged in the dashboard and the asset is blocked from new renders.
- Estimated cost: stock via free-tier / licensed plans is an estimate in the range of Rs. 0 to Rs. 4,000 per month at MVP volume - confirm the current plan terms before launch, as provider pricing changes.

YouTube clips - opt-in only, per project

Downloading YouTube content can breach YouTube's terms and the rights holder's copyright. The product therefore treats it as a high-risk exception, not a feature:

- **Off by default** at account and project level. A user must explicitly enable it for a single project and accept a plain-language risk notice before any URL field appears.
- **Attestation per project:** the user confirms they own the content, or have permission, or that their use is covered by an applicable exception. The attestation, account, timestamp and project ID are stored.
- **Provenance per clip - mandatory:** source URL, channel / uploader as shown on the source page, video title, segment in / out points, retrieval date, and the basis claimed (own content / licensed / permission / exception). A clip without a complete record cannot be added to the timeline or rendered.
- **No circumvention:** no bypassing access controls, age gates, DRM or paid / private content. Private, unlisted-without-access and paywalled sources are refused.
- **No redistribution library:** downloaded segments live inside that one project only. They are not pooled, searchable by other users, or reused across accounts.
- **Takedown:** on a valid rights-holder complaint, the clip and any render containing it are removed under the process in Section 7, even if the user attested otherwise. The attestation shifts responsibility; it does not remove our duty to act on notice.

User uploads, music and AI output

- **Uploads:** user confirms they have the rights to use uploaded media. File-type and size checks run on upload; executables and disguised file types are rejected.
- **Music / sound:** only tracks from the licensed library shipped with the product, or user uploads with provenance. No ripping audio from third-party video as a music source.
- **AI-generated assets:** recorded as generated, with model / provider, prompt and date. Do not label generated media as real footage in the publish pack. Where a platform requires AI-content disclosure, the publish pack includes that disclosure text by default.
- **Publish pack:** title, description and thumbnail exports include the attribution lines required by the provenance records in that project - generated automatically, not left to the user to remember.

6 Open-source licensing and the clean-room rule

AI Video Studio is a closed, paid product sold on credits / subscription, because we carry render and provider costs on every job. That model is incompatible with accidentally absorbing copyleft code. The rules below are how we borrow ideas without borrowing obligations we cannot meet.

The clean-room rule - applies to every contributor

- **Do not copy** code, UI copy, help text, templates, project structure or visual design from Slot Studio, OpenChatCut, Palmier Pro or Pallaidium - or from any product we benchmark.
- **Patterns are allowed, expression is not.** We may adopt an idea in our own words and our own code - for example an editable timeline, chat-driven edit proposals the user approves before they apply, or a swappable generation backend. Implementation is written from our own specifications.
- **Separation:** anyone who has read a copyleft codebase in detail writes a short pattern note (what it does, not how it is coded). Implementation is done from that note, not from the source open beside the editor.
- **Evidence:** pattern notes, specifications and commit history are kept. If our originality is ever questioned, that trail is the answer.
- **Screenshots and assets:** no screenshots, icons, sample media or brand elements from reference products in our product, docs or marketing.

Reference	Licence position	What it means for us
OpenChatCut	AGPL-3.0	Network-use copyleft. If we ran modified AGPL code as our service, source for that service would have to be offered to its users. We do not use its code, components or templates in any form.
Pallaidium	GPL-3.0	Distribution copyleft. We do not use its code or ship anything derived from it, including inside a Blender-based pipeline.
Palmier Pro	GPL only through v0.7.6, proprietary after	Later versions are not open source at all. No code from any version is used. Version confusion is not a defence - treat the whole project as off-limits for code.
Slot Studio	Commercial product	A competitor, not a source. No copying of its workflow text, pricing page, templates or outputs beyond observing publicly what the product does.

Licences we do build on - checked, not assumed

- **Remotion:** not free for all commercial use - it operates its own company licensing terms above certain team / company thresholds. Before MVP launch, confirm which Remotion licence our company size and use require, budget it as an estimated cost, and record the licence in the software bill of materials. If the terms do not fit, the fallback is an ffmpeg-only motion-graphics path - that decision is made before, not after, the timeline editor is built on Remotion.
- **faster-whisper / Whisper models, ffmpeg and other libraries:** each dependency is recorded with its licence at adoption. ffmpeg builds vary by included codecs - use a build whose licence and codec set are compatible with a commercial, hosted product, and record the exact build.
- **Fonts, icons, stock and music:** same rule as code - licence recorded per asset family before it ships.
- **Software bill of materials (SBOM):** generated in CI on every release, listing every direct and transitive dependency and its licence. A new dependency with AGPL, GPL, SSPL or an unknown licence fails the build until the licensing owner approves it in writing in the pull request.
- **Our own terms:** users retain rights in their scripts and uploads. We take only the licence needed to process, store, render and deliver their projects, as stated in the user terms. Generated output rights follow the underlying model / provider terms, which the publish pack surfaces where they restrict commercial use.

7 Content moderation and abuse

Prohibited content - blocked, not debated at render time

- Child sexual abuse material - zero tolerance, immediate block, account termination and reporting as required by law.
- Non-consensual intimate imagery, and voice cloning or impersonation of a real person without their consent.
- Content whose main purpose is fraud, impersonation of a brand or official body, or evading another platform's enforcement.
- Unlabelled synthetic media presented as real news footage of a real event or person.

How moderation works in the pipeline

Stage	Check
Upload / import	File-type validation, malware scan, hash matching against known prohibited material where a service is available, provenance completeness.
Script / generation	Automated text and image screening on prompts and generated assets. A flag pauses the job - it does not silently rewrite the user's content.
Pre-render	Flagged projects go to a human review queue. No flagged project renders until a reviewer clears or rejects it. Review decision and reviewer ID are audit-logged.
Post-publish reports	Public report route for rights holders and viewers. Acknowledged within 2 business days; infringing or prohibited content removed within 5 business days of a valid notice, faster for safety-critical categories.

- **Repeat offenders:** first valid copyright / policy strike - warning and content removed. Second - rendering paused for 30 days. Third - account terminated. Safety-critical categories skip straight to termination.
- **Appeals:** user can appeal a moderation or takedown decision once, in-product, with a written reason. A different reviewer decides the appeal.
- **Abuse of the platform itself:** credit farming, account sharing to evade limits, scraping, and automated sign-ups are grounds for suspension. Rate limits in Section 2 are the first line; billing anomalies are reviewed daily in MVP.
- Estimated moderation cost: automated screening APIs are an estimate in the range of Rs. 2,000 to Rs. 10,000 per month at MVP volume, plus reviewer time - re-check at current provider pricing before launch.

8 Audit log, incidents and launch gate

Audit log - append-only, tamper-evident

Every event below is recorded with actor, account, timestamp (UTC), IP where relevant, object ID and outcome. Users can view events for their own account; the full log is Admin-only.

- Sign-in success / failure, password change, reset, MFA enrolment, session revocation
- BYOK added, validated, used by a job (provider and job ID only - never the key), revoked
- Project create / delete, media upload, asset import with provenance, YouTube opt-in and attestation
- Render requested / completed / failed, publish pack exported, credit purchase / refund
- Support or Admin access to a user project, with the grant reason and expiry
- Moderation flag, review decision, takedown, strike, appeal and its outcome
- Account soft-delete, hard purge, and data export

Incident response - the short version kept in the runbook

Contain first (revoke keys / sessions, pause the affected worker), then assess scope from the audit log, then notify. Users affected by a breach involving their personal data are notified without undue delay, and regulators where the applicable law requires it. Every incident gets a written post-incident note: what happened, what data was involved, what changed. Key leakage is always an incident, even if no misuse is found.

Open decision - the only one in this document: primary storage region.
Option A - India: lowest latency for the first market, simplest local tax / data story; fewer managed-service options.
Option B - EU (Frankfurt / Ireland): strongest privacy positioning; higher latency for India users and higher estimated storage / egress cost.
Option C - US: widest service and model-provider availability; weakest fit if India or EU users expect local residency.
Decide before staging is provisioned - bucket region, database region and backups must match, and moving later means a full media migration. Everything else in this document is decided and buildable as written.

Launch gate - all must pass

- Auth, session, rate-limit and admin-MFA checks tested; secret scanning active in CI
- BYOK encryption, masking and revocation tested end to end
- Retention jobs running on schedule with deletion proven on a test account
- Provenance record enforced - render blocked without it; YouTube path off by default
- SBOM generated; Remotion licence confirmed and recorded; no unapproved copyleft dependency
- Moderation queue, takedown route and appeals working; audit log capturing every event above

Related production documents: Product Requirements, Architecture and Data, API Specification, UI/UX Specification, AI Pipeline Specification, Testing and DevOps, Pricing and Launch. This document governs where any of them conflicts with it on security, privacy, copyright or licensing.